Software Requirements Specification (SRS)

Document Title: Gadaa Istar Export E-Commerce Platform — Software Requirements Specification

Prepared for: Information Network Security Administration (INSA), Cyber Security Audit Division

Prepared by: Gadaa Istar J&M Business Group plc

Application: Gadaa Istar Export E-Commerce Platform (internal code name: `gcomerce`)

Document version: 1.0

Date: July 2026

1. Introduction

1.1 Purpose

This Software Requirements Specification (SRS) defines the functional and non-functional requirements for the **Gadaa Istar Export E-Commerce Platform** (`gcomerce`). It is submitted to the Information Network Security Administration (INSA) as part of the documentation package required

for the web application security audit, in line with the INSA *Web Application Testing Requirement* guidance.

The document is written for the following audiences:

- INSA security auditors and penetration testers who need a precise description of what the system does, who its users are, and what security-relevant behaviour is in scope.

- Gadaa Istar engineering, product, and compliance stakeholders who use it as the baseline reference for development, change control, and audit traceability.

- Payment and infrastructure partners (MPGS, Cloudflare, Ethio Telecom Cloud) who need to understand the interfaces the platform exposes and consumes.

This SRS is intentionally implementation-aware: it describes requirements at a level specific enough to be verified by inspection, testing, or demonstration, while leaving the *how* (architecture, components, data model) to the companion **System & Architecture Design Document (SDD)**.

1.2 Scope

The system covered by this SRS is a custom-developed, hybrid **B2B + B2C e-commerce platform** that enables international buyers to browse an export product catalog, request quotes (B2B), place orders, and pay through a hosted payment gateway. The platform is owned and operated by Gadaa Istar J&M Business Group plc and is hosted on Ethio Telecom Cloud with Cloudflare providing edge security and CDN.

The platform comprises three primary surfaces, all of which are in scope:

1. **Public storefront** — `https://gadaaistar.et` — customer-facing product catalog, cart, checkout, and self-service account portal (server-side rendered).

2. **Admin back-office** — `https://admin.gadaaistar.et` — internal management of products, inventory, pricing, orders, customers, quotes, coupons, CMS, shipping, and refunds (single-page application).

3. **REST APIs** — `https://api.gadaaistar.et` — two Quarkus runtime modules (`api-storefront` and `api-admin`) serving the storefront and admin frontends respectively.

Out of scope for this SRS:

- The MPGS hosted payment page itself (a PCI-DSS-certified third-party service; the platform never receives raw card data).

- Cloudflare's internal edge infrastructure and WAF engine internals.

- Ethio Telecom Cloud's underlying hypervisor and physical infrastructure.

- Third-party SMTP relay infrastructure in production.

- End-user devices (customer browsers, admin workstations).

- Native mobile applications (none exist; the storefront is responsive web).

1.3 Definitions, Acronyms, and Abbreviations

Term	Definition
API	Application Programming Interface
B2B / B2C	Business-to-Business / Business-to-Consumer
BCrypt	Adaptive password hashing function (cost factor 12 used here)
CDN	Content Delivery Network
CMS	Content Management System
CORS	Cross-Origin Resource Sharing
CSRF	Cross-Site Request Forgery
CVV	Card Verification Value
DTO	Data Transfer Object

ERCA	Ethiopian Revenue and Customs Authority
HMAC	Hash-based Message Authentication Code
HS256	HMAC with SHA-256 (JWT signing algorithm)
HSTS	HTTP Strict Transport Security
INSA	Information Network Security Administration
JAX-RS	Java API for RESTful Web Services
JPA	Jakarta Persistence API
JWT	JSON Web Token (RFC 7519)
MFA	Multi-Factor Authentication
MOQ	Minimum Order Quantity
MPGS	Mastercard Payment Gateway Services
NFR	Non-Functional Requirement
ORM	Object-Relational Mapping
PAN	Primary Account Number (credit card number)
PCI DSS	Payment Card Industry Data Security Standard
RBAC	Role-Based Access Control
REST	Representational State Transfer
SAQ-A	PCI DSS Self-Assessment Questionnaire A
SDD	System & Architecture Design Document (companion document)
SLO	Service Level Objective
SMTP	Simple Mail Transfer Protocol
SPA	Single Page Application
SQL	Structured Query Language
SSR	Server-Side Rendering
SRS	Software Requirements Specification (this document)
TLS	Transport Layer Security
TOTP	Time-Based One-Time Password (RFC 6238)
TTL	Time To Live
UUID	Universally Unique Identifier

VAT	Value Added Tax
WAF	Web Application Firewall
XSS	Cross-Site Scripting

1.4 References

- INSA *Web Application Testing Requirement* document (scope and mandatory information list).

- OWASP Top 10 (2021) and OWASP Secure Coding Practices.

- PCI DSS v4.x and SAQ-A (hosted-payment, no card data on merchant servers).

- RFC 7519 (JWT), RFC 6238 (TOTP), RFC 4648 (Base32), RFC 5849 (HMAC).

- ERCA VAT guidance for Ethiopian export (zero-rated exports, 15% domestic standard).

- Companion: *System & Architecture Design Document (SDD)*, same version and date.

1.5 Overview

Section 2 describes the system at the product level: its perspective, the functions it provides, its users, and the constraints under which it operates. Section 3 lists the specific, verifiable requirements — external interfaces, functional requirements grouped by feature area, and non-functional requirements (security, performance, reliability, maintainability, compliance). Section 4 covers supporting information: data requirements, traceability, and a glossary supplement.

2. Overall Description

2.1 Product Perspective

The Gadaa Istar Export E-Commerce Platform is a self-contained system developed and operated by Gadaa Istar J&M Business Group plc. It is not a packaged product; it is a bespoke platform built to modernise and scale the company's international export operations. It replaces a manual, email-and-spreadsheet ordering process with a secure, self-service online channel.

The system is composed of the following cooperating subsystems:

Subsystem	Technology	Role
Storefront frontend	Angular 20 (standalone components, signals, SSR)	Customer-facing web application rendered server-side for SEO and first-paint performance
Admin frontend	Angular 20 (standalone components, SPA)	Internal back-office single-page application
Storefront API	Java 21 + Quarkus 3.15.1 (RESTEasy Reactive)	Public/customer REST API (/api/storefront/v1)
Admin API	Java 21 + Quarkus 3.15.1 (RESTEasy Reactive)	Internal admin REST API (/api/admin/v1)
Persistence	PostgreSQL 16 + Flyway migrations + Hibernate ORM/Panache	Primary transactional datastore
Object storage	MinIO (dev) / S3-compatible (prod)	Product media, generated thumbnails, invoice storage
Cache / rate-limit	Redis 7 (optional, multi-instance)	Distributed rate limiting and distributed lease for scheduled jobs
Reverse proxy	Nginx	TLS-to-origin, routing, rate limiting, security headers
Edge	Cloudflare	TLS termination, WAF, DDoS protection, CDN

Payment	MPGS (Mastercard Payment Gateway Services)	Hosted-checkout card payment with HMAC-signed webhook callbacks
Email	SMTP relay (MailHog in dev)	Transactional email: verification, reset, shipment, B2B, coupon reports

The two Quarkus runtimes share a single PostgreSQL database (`GCOMERCE`) and a single schema. The `api-storefront` runtime owns Flyway migration execution; `api-admin` has Flyway disabled to avoid dual-runner conflicts. Both runtimes share security infrastructure (JWT, BCrypt, TOTP, rate limiting, exception handling) through a common `web-common` module.

2.2 Product Functions

At a high level, the platform provides the following functions. Each is elaborated as a set of verifiable functional requirements in Section 3.2.

1. **Customer authentication and account management** — registration (B2C and B2B), email verification, login, JWT-based session, profile management, password change/reset, address book.

2. **Catalog browsing** — product listing by category, search, product detail pages, CMS pages and banners, SEO endpoints (robots.txt, sitemap.xml).

3. **Cart and checkout** — guest and authenticated carts, cart merge on sign-in, address selection, shipping quotes, coupon validation, order placement, hosted-payment redirect, payment success/cancel handling.

4. **B2B quote workflow** — quote request from cart, admin review and pricing, quote sent to customer, customer acceptance, conversion to an order.

5. **Order management** — order history, order detail, public order tracking, status lifecycle (PENDING_PAYMENT → PAID → FULFILLING → SHIPPED → DELIVERED / CANCELLED), refunds.

6. **Payment processing** — MPGS hosted-checkout session creation, webhook verification, idempotent payment confirmation, pull-based confirmation fallback, refund initiation from admin.

7. **Admin back-office** — product/variant/inventory/pricing management, customer and customer-group management, order and quote management, coupon management, CMS pages and banners, shipping methods and rate zones, admin user management and MFA reset, dashboard stats.

8. **Admin authentication with mandatory MFA** — two-step login (password then TOTP), MFA enrollment with QR code, MFA reset by SUPERADMIN, session hardening (max lifetime, idle timeout).

9. **Tax and invoicing** — ERCA-compliant VAT (STANDARD 15%, EXPORT zero-rated, EXEMPT), gap-free per-fiscal-year invoice numbering, credit notes.

10. **Operational automation** — abandoned-order sweeper, coupon expiry and usage reports, stale rate-limit key reaping.

11. **Observability and operability** — health checks, Prometheus metrics, structured JSON logging, correlation IDs, OpenAPI/Swagger UI.

2.3 User Characteristics

The system has the following actor types. Their capabilities, authentication method, and audience separation are summarised here and enforced as requirements in Section 3.2.

Actor	Audience	Authentication	Description
Anonymous visitor	—	None	Browses public catalog and CMS pages; can build a guest cart
B2C customer	STOREFRONT	Email + password (BCrypt) → JWT	Retail buyer; places orders at retail pricing
B2B customer	STOREFRONT	Email + password (BCrypt) → JWT	Wholesale buyer; requests quotes, sees wholesale pricing, MOQ enforcement

B2B admin viewer	STOREFRONT	JWT (email allowlist)	Internal account that can view all customer transactions
Admin — SUPERADMIN	ADMIN	Email + password + TOTP MFA → JWT	Full access to all admin modules and settings; can reset other admins' MFA
Admin — PRODUCT_MANAGER	ADMIN	Email + password + TOTP MFA → JWT	Products, variants, inventory, pricing, CMS, coupons
Admin — ORDER_MANAGER	ADMIN	Email + password + TOTP MFA → JWT	Orders, shipments, refunds, shipping methods
Admin — CUSTOMER_MANAGER	ADMIN	Email + password + TOTP MFA → JWT	Customer accounts, B2B approvals, customer groups
Admin — FINANCE	ADMIN	Email + password + TOTP MFA → JWT	Orders (read), reports, refunds
MPGS gateway	—	Notification secret (webhook)	Server-to-server payment callback

Users are expected to have basic web literacy. Admin users are internal staff who are trained on the back-office and enrolled in TOTP MFA via an authenticator app (Google Authenticator, Authy, 1Password, etc.). International buyers may have limited familiarity with Ethiopian export context, so the storefront presents prices in USD (default) or ETB and supports English locale.

2.4 Constraints

The following constraints apply to the system and to this specification:

- **Regulatory:** The platform must comply with Ethiopian VAT rules as administered by ERCA (15% standard domestic, zero-rated exports, exempt classes) and must produce gap-free, auditable invoice sequences per fiscal year.

- **Payment compliance:** The platform must operate under PCI DSS SAQ-A. Card data (PAN, CVV) must never be received, processed, stored, or transmitted by the platform's servers. All card entry occurs on the MPGS hosted payment page.

- **Hosting:** Production runs on Ethio Telecom Cloud within Ethiopia, with Cloudflare as the edge layer.

- **Technology baseline:** Backend must be Java 21 + Quarkus; frontend must be Angular 20; database must be PostgreSQL 16. These are fixed architectural decisions, not options.

- **Statelessness:** The backend must be stateless to permit horizontal scaling; all session state lives in JWTs, not server-side sessions.

- **No raw SQL:** All database access must use parameterised queries via JPA/Hibernate and Panache repositories. String-concatenated SQL is prohibited.

- **No cookies for authentication:** Authentication must use `Authorization: Bearer` headers, not cookies, to eliminate CSRF risk for auth.

- **Mandatory MFA for admins:** All admin accounts must use TOTP MFA. There is no admin login path that bypasses MFA.

- **Secrets management:** Secrets must never appear in source code or committed config files. In dev they come from environment variables; in staging/production they come from HashiCorp Vault.

- **Audit timeline:** INSA requires a reply to requirements within five (5) days; this document set is produced to meet that timeline.

2.5 Assumptions and Dependencies

- MPGS merchant credentials (merchant ID, API password, notification secret) are provisioned and valid.

- Cloudflare zone, origin certificate, and WAF rules are configured for `gadaaistar.et`, `admin.gadaaistar.et`, and `api.gadaaistar.et`.

- Ethio Telecom Cloud provides the compute, network, and managed PostgreSQL used in production.

- An SMTP relay is available in production for transactional email delivery.

- International buyers have internet access and a modern browser; no legacy browser support is required.

- Admin workstations have an authenticator app installed for TOTP enrollment.

3. Specific Requirements

3.1 External Interfaces

3.1.1 User Interfaces

Storefront UI (Angular 20 SSR):

- Responsive web application targeting modern evergreen browsers (Chrome, Firefox, Safari, Edge).

- Server-side rendered for first-paint performance and SEO; hydrates to a client-side app.

- Brand identity derived from the Gadaa Istar logo (navy, red, gold, cream palette) via a shared `ui-kit` library.

- Material Design 3 theming with custom brand colors.

- Routes: home, shop (with category filter), product detail, cart, checkout (with return/cancel callbacks), account portal (profile, addresses, orders, transactions, quotes), login, register, forgot/reset password, email verification, order tracking, wishlist, CMS pages.

- Route guards: `authGuard` (blocks anonymous from protected routes), `guestGuard` (prevents signed-in users from login/register).

- Client-side validation mirrors backend Bean Validation (email format, min password length 8, field max lengths, B2B company fields required when type is B2B).

Admin UI (Angular 20 SPA):

- Single-page application, no SSR (internal tool, SEO not relevant).

- Routes: login, MFA verify/enroll, dashboard, admin users, products (list + tabbed editor: details, media, inventory, pricing, variants), price lists, shipping methods, orders, quotes, customers, customer groups, coupons, CMS pages, CMS banners.

- Route guards: `authGuard`, `guestGuard`, `mfaChallengeGuard` (only allows `/verify-mfa` when a pending MFA challenge exists).

- Idle timeout: 10 minutes of inactivity forces logout.

- Session stored in `sessionStorage` (clears on tab close); storefront session in `localStorage`.

3.1.2 Hardware Interfaces

No direct hardware interfaces. The system interacts with infrastructure (PostgreSQL, MinIO/S3, Redis, SMTP) over standard network protocols.

3.1.3 Software Interfaces (External Integrations)

Integration	Purpose	Direction	Authentication
MPGS	Card payment via hosted checkout; refunds via REST API	Browser → MPGS hosted page; Backend → MPGS REST API; MPGS → backend webhook	Merchant ID + API password; webhook verified via notification secret (constant-time comparison)

SMTP relay	Transactional email (verification, reset, shipment, B2B, coupon reports)	Backend → SMTP	Username + password (prod); MailHog (dev)
MinIO / S3	Product media, thumbnails, invoice storage	Backend → S3 API	Access key + secret key
Cloudflare Turnstile / reCAPTCHA	Contact form bot protection	Browser → Cloudflare	Site key + secret key
Cloudflare Edge	TLS, WAF, CDN, DDoS protection	All inbound traffic	Cloudflare origin certificate (Full-Strict)
HashiCorp Vault	Secret storage (prod/staging)	Backend → Vault on startup	Vault token / auth method

GADAA ISTAR
J&M BUSINESS GROUP PLC

3.1.4 Communications Interfaces

Channel	**Protection**
Browser ↔ Cloudflare edge	TLS 1.2/1.3, HSTS (max-age=63072000; includeSubDomains; preload)
Cloudflare edge ↔ Nginx origin	TLS Full-Strict (Cloudflare origin certificate)
Nginx ↔ Quarkus / Node.js	Internal Docker network / private subnet; HTTP internally; TLS terminates at edge
Backend ↔ PostgreSQL	JDBC over internal network; TLS configurable via quarkus.datasource.jdbc.ssl-mode=require in prod
Backend ↔ Redis	redis:// (internal); upgradeable to rediss:// for TLS
Backend ↔ MPGS	HTTPS (https://mtf.gateway.mastercard.com test / production gateway)
Backend ↔ SMTP	STARTTLS configurable; disabled in dev (MailHog), enabled in prod

Backend ↔ S3 / MinIO	HTTPS in prod; HTTP in dev (local MinIO)

3.2 Functional Requirements

Functional requirements are grouped by feature area. Each requirement has a stable identifier (`FR-XX-NNN`) for traceability. Requirements marked **[RBAC]** are enforced at the database, application, and frontend layers.

3.2.1 Customer Authentication and Account Management (FR-AUTH)

ID	Requirement
FR-AUTH-001	The system shall allow a visitor to register as a B2C or B2B customer by submitting email, password (min 8 chars), first/last name, customer type, and (for B2B) company name and TIN.
FR-AUTH-002	The system shall hash all customer passwords using BCrypt at cost factor 12 before storage. Plaintext passwords shall never be stored or logged.
FR-AUTH-003	The system shall create new customer accounts in PENDING_VERIFICATION status and send a time-limited email verification token (TTL 60 minutes).
FR-AUTH-004	The system shall activate a customer account (transition to ACTIVE) only after the email verification token is consumed.
FR-AUTH-005	The system shall allow a customer to log in with email and password and, on success, issue a JWT access token (HS256, 15-minute TTL) and a rotating refresh token (30-day TTL, SHA-256 hashed at rest).

FR-AUTH-006	The system shall normalise all email inputs by trimming and lowercasing before lookup/insert to prevent case-sensitivity bypass.
FR-AUTH-007	The system shall return the same error (INVALID_CREDENTIALS) for an unknown email and for an invalid password to prevent user enumeration.
FR-AUTH-008	The system shall allow a customer to refresh an access token by presenting a valid, non-revoked refresh token; on refresh, the old refresh token shall be invalidated and a new one issued (rotation), with the replacement recorded for audit.
FR-AUTH-009	The system shall allow a customer to log out by revoking the presented refresh token.
FR-AUTH-010	The system shall revoke all of a customer's refresh tokens on password change or password reset.
FR-AUTH-011	The system shall allow a customer to request a password reset link (TTL 30 minutes) by email; the link shall be single-use.
FR-AUTH-012	The system shall allow a customer to change their password by providing the current password and a new password (with confirmation); on success all sessions are revoked.
FR-AUTH-013	The system shall allow an authenticated customer to view and update their profile (first/last name, phone, company details, preferred currency/locale).
FR-AUTH-014	The system shall enforce audience separation: a storefront JWT (aud_type=STOREFRONT) shall not be accepted on admin endpoints, and vice versa.

FR-AUTH-015	The system shall rate-limit authentication endpoints: login 10/60s, register 5/10min, resend-verification 3/10min, forgot-password 3/10min, reset-password 10/10min, change-password 5/10min.
FR-AUTH-016	The system shall support a B2B admin viewer account (email allowlist) that can view all customer transactions from the storefront account portal.

3.2.2 Admin Authentication and MFA (FR-ADMIN-AUTH)

ID	Requirement
FR-ADMIN-AUTH-001	The system shall require all admin accounts to authenticate with email + password followed by a TOTP (RFC 6238) second factor. No admin login path shall bypass MFA.
FR-ADMIN-AUTH-002	The system shall implement login as a two-step flow: step 1 verifies credentials and returns a short-lived MFA challenge token (purpose-scoped JWT, TTL 300 seconds); step 2 verifies the TOTP code and issues access + refresh tokens.
FR-ADMIN-AUTH-003	The system shall generate TOTP secrets as 20 random bytes, base32-encoded (RFC 4648), and present an otpauth:// provisioning URI for QR-code enrollment in an authenticator app.
FR-ADMIN-AUTH-004	The system shall verify TOTP codes with a configurable window tolerance (default ±1 step, 30-second step, 6 digits) using constant-time comparison to prevent timing attacks.

FR-ADMIN-AUTH-005	The system shall allow a SUPERADMIN to reset another admin's MFA (wipe TOTP secret and revoke all sessions); an admin shall not be able to reset their own MFA.
FR-ADMIN-AUTH-006	The system shall enforce an admin session maximum lifetime (default 480 minutes / 8 hours) and an idle timeout (default 10 minutes); exceeding either shall force logout.
FR-ADMIN-AUTH-007	The system shall enforce RBAC with five seeded admin roles: SUPERADMIN, PRODUCT_MANAGER, ORDER_MANAGER, CUSTOMER_MANAGER, FINANCE.
FR-ADMIN-AUTH-008	The system shall enforce role checks on every sensitive admin endpoint via requireAnyRole(...); a caller lacking any allowed role shall receive HTTP 403. [RBAC]
FR-ADMIN-AUTH-009	The system shall rate-limit admin auth endpoints at the Nginx layer (gi_auth_zone, 5 r/s) and at the application layer.

3.2.3 Catalog and Browsing (FR-CATALOG)

ID	Requirement
FR-CATALOG-001	The system shall expose a public product listing endpoint that returns only ACTIVE products, with optional category filter and pagination.
FR-CATALOG-002	The system shall expose a public product search endpoint (by SKU, name, or slug).
FR-CATALOG-003	The system shall expose a public product detail endpoint by slug, returning full

	product information including media, variants, and pricing.
FR-CATALOG-004	The system shall render product listing and detail pages server-side (SSR) for SEO and fast first paint.
FR-CATALOG-005	The system shall serve a robots.txt and a sitemap.xml from dedicated SEO endpoints.
FR-CATALOG-006	The system shall expose public CMS page and banner endpoints returning only published/active content.
FR-CATALOG-007	The system shall generate two server-side image thumbnails per uploaded product image: 300px (card) and 800px (detail).

GADAA ISTAR
J&M BUSINESS GROUP PLC

3.2.4 Cart and Checkout (FR-CART)

ID	Requirement
FR-CART-001	The system shall support a guest cart (identified by an X-Guest-Session-Key header) and an authenticated cart (tied to the customer).
FR-CART-002	The system shall merge a guest cart into the customer's cart on sign-in.
FR-CART-003	The system shall allow adding, updating quantity (0 removes), and removing cart line items, with per-product/variant uniqueness enforced.
FR-CART-004	The system shall snapshot the unit price into the cart line at add time to preserve price integrity.
FR-CART-005	The system shall rate-limit cart mutation endpoints (60/60s).
FR-CART-006	The system shall allow an authenticated customer to place an order from their

	cart; on placement the cart shall be frozen into the order with status PENDING_PAYMENT and inventory reserved.
FR-CART-007	The system shall support an Idempotency-Key header on order creation to prevent duplicate orders from network retries.
FR-CART-008	The system shall rate-limit order placement (6/60s).
FR-CART-009	The system shall allow a customer to select a shipping address, billing address, and shipping method during checkout, and to retrieve live shipping quotes for their cart.
FR-CART-010	The system shall allow a customer to validate a coupon code against the current cart and apply the resulting discount at order placement.

3.2.5 B2B Quote Workflow (FR-QUOTE)

ID	Requirement
FR-QUOTE-001	The system shall allow a B2B customer to submit a quote request from their cart; the quote shall enter SUBMITTED status.
FR-QUOTE-002	The system shall allow an admin to review a quote (UNDER_REVIEW), edit proposed unit prices per line item, and send the quote to the customer (SENT) with a validity period.
FR-QUOTE-003	The system shall allow a B2B customer to accept a SENT quote (ACCEPTED).

FR-QUOTE-004	The system shall allow an admin to convert an ACCEPTED quote into a PENDING_PAYMENT order (CONVERTED).
FR-QUOTE-005	The system shall allow an admin to reject a quote (REJECTED).
FR-QUOTE-006	The system shall rate-limit quote creation (5/300s).
FR-QUOTE-007	The system shall enforce MOQ (minimum order quantity) and wholesale pricing tiers for B2B customers based on their customer group.

3.2.6 Order Management (FR-ORDER)

ID	Requirement
FR-ORDER-001	The system shall maintain an order status lifecycle: PENDING_PAYMENT → PAID → FULFILLING → SHIPPED → DELIVERED, with CANCELLED and refund states available.
FR-ORDER-002	The system shall record every status transition in an order_status_event audit log (from, to, source, actor, timestamp, note).
FR-ORDER-003	The system shall allow a customer to view their order history (paginated) and individual order details.
FR-ORDER-004	The system shall expose a public order-tracking endpoint (by UUID, no auth) for shipment status.
FR-ORDER-005	The system shall allow an admin to list orders with status/search filters and to transition an order's status (mark shipped, delivered, cancelled).

FR-ORDER-006	The system shall auto-cancel PENDING_PAYMENT orders older than a configurable TTL (default 60 minutes) via a scheduled sweeper, releasing reserved inventory.
FR-ORDER-007	The sweeper shall use a distributed lease to prevent concurrent execution across replicas.

3.2.7 Payment Processing (FR-PAY)

ID	Requirement
FR-PAY-001	The system shall integrate with MPGS using hosted checkout: the backend creates a checkout session and the customer enters card data on the MPGS-hosted page. The platform shall never receive PAN or CVV.
FR-PAY-002	The system shall store the MPGS session ID and success indicator on the order at session creation.
FR-PAY-003	The system shall accept MPGS webhook notifications and verify the notification secret using constant-time comparison before processing.
FR-PAY-004	The system shall mark an order PAID on a successful CAPTURE/AUTHORIZE webhook and shall mark payment failed on FAILED/CANCELLED.
FR-PAY-005	The system shall process payment webhooks idempotently: a webhook for an order already moved out of PENDING_PAYMENT shall be ignored.

FR-PAY-006	The system shall provide a pull-based MPGS confirmation fallback endpoint for cases where the webhook is delayed.
FR-PAY-007	The system shall allow an admin (ORDER_MANAGER / SUPERADMIN) to issue a refund against a paid order via the MPGS REST API, with a MANUAL fallback when gateway credentials are not configured.
FR-PAY-008	The system shall record each refund attempt (amount, reason, status, gateway reference, initiating admin) in an order_refund table and track a refunded_total on the order.
FR-PAY-009	The webhook endpoint shall be excluded from Nginx rate limiting to avoid dropping legitimate gateway callbacks.
FR-PAY-010	The system shall not log failed webhook signature bodies (defence against attackers spraying malformed POSTs).

3.2.8 Tax and Invoicing (FR-TAX)

ID	Requirement
FR-TAX-001	The system shall support three tax classes: STANDARD (15% VAT, domestic), EXPORT (zero-rated), and EXEMPT.
FR-TAX-002	The system shall resolve the applicable tax rule by country code and tax class and compute tax per order line.
FR-TAX-003	The system shall generate gap-free, per-fiscal-year invoice numbers using SELECT ... FOR UPDATE serialisation, with a configurable prefix (default GI) and fiscal-year start month (default 7).

FR-TAX-004	The system shall support credit notes (prefix CN) for refunds.

3.2.9 Admin Back-Office — Products, Inventory, Pricing (FR-PROD)

ID	Requirement
FR-PROD-001	The system shall allow PRODUCT_MANAGER / SUPERADMIN to create, update, archive (soft-delete), and view products with SKU, slug, name, category, weight, HS code, origin country, tax class, base price, cost price, and MOQ. [RBAC]
FR-PROD-002	The system shall allow product variants (SKU, name, price override, weight override, attributes) with variant-level inventory. [RBAC]
FR-PROD-003	The system shall allow inventory management by signed delta (adjust) or absolute overwrite (quantity + restock threshold). [RBAC]
FR-PROD-004	The system shall allow price lists per customer group with tiered entries (price by min quantity) and effective date ranges. [RBAC]
FR-PROD-005	The system shall allow product media upload to S3/MinIO with MIME validation, max upload size (default 20 MB), and automatic thumbnail generation. [RBAC]
FR-PROD-006	The system shall support product CSV import and export. [RBAC]

3.2.10 Admin Back-Office — Customers, Groups, Orders, Quotes, Coupons, CMS, Shipping (FR-ADMIN)

ID	Requirement
FR-ADMIN-001	The system shall allow CUSTOMER_MANAGER / SUPERADMIN to list/view customers, change customer status, approve pending B2B customers, force-verify email, revoke sessions, issue password reset, and assign customer groups. [RBAC]
FR-ADMIN-002	The system shall allow CUSTOMER_MANAGER / SUPERADMIN to manage customer groups (code, name, price tier, MOQ multiplier). [RBAC]
FR-ADMIN-003	The system shall allow ORDER_MANAGER / SUPERADMIN to manage shipping methods (base cost, per-kg rate, min/max days) and per-country rate zones. [RBAC]
FR-ADMIN-004	The system shall allow PRODUCT_MANAGER / SUPERADMIN to manage coupons (percentage or fixed amount, min subtotal, free shipping, max redemptions, max per customer, validity window). [RBAC]
FR-ADMIN-005	The system shall run a daily coupon expiry check (default 08:00 UTC, 7-day warning) and a weekly usage report (Monday 09:00 UTC) emailed to finance.
FR-ADMIN-006	The system shall allow PRODUCT_MANAGER / SUPERADMIN to manage CMS pages (slug, title, body HTML, SEO metadata) and banners (placement, image, link, schedule). [RBAC]

FR-ADMIN-007	The system shall expose a dashboard stats endpoint with KPI tiles (revenue, orders, low stock, etc.).

3.2.11 Observability and Operability (FR-OPS)

ID	Requirement
FR-OPS-001	The system shall expose health check endpoints (/q/health) for both Quarkus runtimes.
FR-OPS-002	The system shall expose Prometheus metrics (/q/metrics) including a gi_ratelimit_requests_total{backend,result} counter and gi_ratelimit_active_keys{backend} gauge.
FR-OPS-003	The system shall attach a correlation ID (X-Correlation-Id) to every request (from header or generated), write it to the SLF4J MDC, and echo it in the response header.
FR-OPS-004	The system shall use structured JSON console logging in production and shall disable SQL logging in production.
FR-OPS-005	The system shall expose OpenAPI 3 spec and Swagger UI.
FR-OPS-006	The system shall reap stale in-memory rate-limit keys (no hits in 15 minutes) every 5 minutes to bound memory use.

3.3 Non-Functional Requirements

3.3.1 Security (NFR-SEC)

ID	Requirement
NFR-SEC-001	Authentication — All customer and admin passwords shall be hashed with BCrypt cost 12. JWTs shall be HS256-signed with separate secrets for storefront and admin audiences, each minimum 32 characters, loaded from environment variables (dev) or HashiCorp Vault (prod).
NFR-SEC-002	Authorisation — RBAC shall be enforced at three layers: database (role/permission tables), application (SecurityContextHolder.requireAnyRole), and frontend (Angular route guards). No sensitive endpoint shall rely on frontend-only enforcement.
NFR-SEC-003	Input validation — All request DTOs shall use Bean Validation (JSR 380). A global exception mapper shall convert ConstraintViolationException to a structured 400 response and shall never leak stack traces or internal messages on 5xx.
NFR-SEC-004	SQL injection prevention — All database access shall use parameterised queries via JPA/Hibernate and Panache. No string-concatenated SQL shall exist in application code.
NFR-SEC-005	XSS prevention — Angular's contextual template escaping shall be used; innerHTML shall be avoided or sanitized via DomSanitizer. The backend shall return JSON only (no HTML in API responses).
NFR-SEC-006	CSRF — Authentication shall use Bearer headers, not cookies, eliminating CSRF risk for auth. No auth cookies shall be set.
NFR-SEC-007	Session management — Access tokens 15-min TTL; refresh tokens 30-day TTL,

	rotating, SHA-256 hashed at rest, revoked on password change/reset, with IP and User-Agent recorded.
NFR-SEC-008	MFA — TOTP (RFC 6238) shall be mandatory for all admin accounts; verification shall use constant-time comparison across the tolerance window.
NFR-SEC-009	Transport security — TLS 1.2/1.3 everywhere; HSTS with preload; HTTPS-only for all external calls (MPGS, SMTP STARTTLS in prod).
NFR-SEC-010	Security headers — Nginx shall inject: Strict-Transport-Security, X-Frame-Options: DENY, X-Content-Type-Options: nosniff, Referrer-Policy, Permissions-Policy, and X-Robots-Tag: noindex,nofollow (admin only).
NFR-SEC-011	Rate limiting — Defense in depth: Cloudflare edge → Nginx (20 r/s API, 5 r/s auth) → application sliding window (per-endpoint buckets). Application rate limiting shall be disableable in staging for testing.
NFR-SEC-012	Secrets — No secrets in source code or committed config. Dev: environment variables. Prod: HashiCorp Vault.
NFR-SEC-013	Cryptographic practices — BCrypt (passwords), HMAC-SHA256 (JWT signing + payment signatures), SHA-256 (refresh token hashing), SecureRandom for TOTP secrets. No custom cryptography.
NFR-SEC-014	Payment security — PCI DSS SAQ-A: card data never touches platform servers. Webhook signatures verified with constant-time comparison.
NFR-SEC-015	Logging discipline — Passwords, tokens, refresh tokens, payment keys, and card data shall never be logged. Failed

	webhook signature bodies shall not be logged.
NFR-SEC-016	CORS — Only configured storefront and admin origins shall be allowed. Dev profile may allow /.*/ for local development only.
NFR-SEC-017	Idempotency — Order creation and payment webhooks shall support idempotency keys / state checks to prevent duplicate processing.
NFR-SEC-018	Fail secure on auth — Invalid JWTs shall be treated as anonymous (so public endpoints work); endpoint-level requireCustomer()/requireAdmin() enforce auth where needed.
NFR-SEC-019	Dependency hygiene — All dependencies pinned to specific versions (no floating latest); new dependencies require code review; CI runs on every push and PR.

3.3.2 Performance (NFR-PERF)

ID	Requirement
NFR-PERF-001	The storefront API shall respond to catalog read endpoints (list, search, detail) in under 500 ms at the 95th percentile under normal load.
NFR-PERF-002	The storefront SSR shall achieve a first-contentful paint under 2 seconds at the 95th percentile for catalog pages.
NFR-PERF-003	The database connection pool shall be sized max 20 / min 2 per runtime instance.

NFR-PERF-004	Order placement shall complete (excluding the external payment redirect) in under 1 second at the 95th percentile.
NFR-PERF-005	The abandoned-order sweeper shall process in batches (default 100) to avoid long-running transactions.

3.3.3 Reliability and Availability (NFR-REL)

ID	Requirement
NFR-REL-001	The API tier shall be deployable as at least two instances behind Nginx round-robin load balancing with health checks (max_fails=3, fail_timeout=15s).
NFR-REL-002	The storefront SSR tier shall be deployable as at least two instances behind Nginx.
NFR-REL-003	The Redis-backed rate limiter shall fail open on Redis errors (degrading to allowing requests rather than blocking all traffic).
NFR-REL-004	Payment webhook processing shall be idempotent so that duplicate or retried webhooks do not double-process.
NFR-REL-005	Flyway migrations shall be validated in CI to apply cleanly on an empty PostgreSQL 16 database.

3.3.4 Maintainability (NFR-MAINT)

ID	Requirement

NFR-MAINT-001	The backend shall be structured as a multi-module Gradle project with shared infrastructure in a web-common module to avoid duplication.
NFR-MAINT-002	The frontend shall be an Angular workspace with a shared ui-kit library for brand tokens and design system.
NFR-MAINT-003	All configuration shall be externalised via environment variables with sensible dev defaults.
NFR-MAINT-004	CI shall enforce: backend build + unit/integration tests (JUnit 5 + RestAssured + Testcontainers), Flyway validation, frontend ESLint (zero errors) + build.
NFR-MAINT-005	Database schema changes shall be managed exclusively via versioned Flyway migrations; no manual DDL.

3.3.5 Compliance (NFR-COMP)

ID	Requirement
NFR-COMP-001	PCI DSS SAQ-A — The platform shall never receive, process, store, or transmit card data.
NFR-COMP-002	ERCA VAT — The platform shall compute VAT per ERCA rules and produce gap-free invoice sequences.
NFR-COMP-003	OWASP Top 10 — The platform shall mitigate the OWASP Top 10 via the controls enumerated in NFR-SEC.
NFR-COMP-004	Ethiopian national cyber security — The platform shall support the INSA security audit by providing the documentation, test accounts, and (on request) IP

	allowlisting and rate-limit bypass in staging.

3.3.6 Usability (NFR-USE)

ID	Requirement
NFR-USE-001	The storefront shall be responsive and usable on desktop and mobile modern browsers.
NFR-USE-002	Error responses shall be mapped to user-friendly messages in the frontend (e.g., INVALID_CREDENTIALS → "The email or password you entered is incorrect.").
NFR-USE-003	The admin UI shall display a 6-digit TOTP input with a numeric keypad and a QR code for enrollment.

3.4 Data Requirements

The platform's persistent data is managed in a single PostgreSQL 16 database (`GCOMERCE`) with a schema evolved through 20 versioned Flyway migrations. The full data model (entities, fields, relationships, constraints) is documented in the companion **System & Architecture Design Document (SDD)**, Section "Data Model". Key data classes relevant to requirements traceability:

- **Customer & auth:** `customer`, `customer_address`, `customer_group`, `customer_refresh_token`, `email_verification_token`, `password_reset_token`.

- **Admin & RBAC:** `admin_user`, `admin_role`, `role`, `permission`, `role_permission`, `admin_refresh_token`.

- **Catalog:** `product`, `product_variant`, `product_variant_attribute`, `product_media`, `price_list`, `price_list_entry`, `inventory`.

- **Cart & orders:** `cart`, `cart_item`, `checkout_order`, `order_item`, `order_status_event`, `order_refund`.

- **Quotes:** `quote`, `quote_item`.

- **Shipping:** `shipping_method`, `shipping_rate_zone`.

- **Coupons:** `coupon`, `coupon_redemption`.

- **Tax & invoicing:** `tax_class`, `tax_rule`, `invoice_sequence`, `company_tax_profile`.

- **CMS:** `cms_page`, `cms_banner`.

- **Config:** `setting`.

GADAA ISTAR
J&M BUSINESS GROUP PLC

No card data (PAN, CVV) is stored anywhere in the database. Payment references stored on `checkout_order` are gateway transaction IDs only.

4. Supporting Information

4.1 Traceability

Every functional requirement in Section 3.2 is implemented by one or more REST endpoints and services enumerated in the SDD, and is verifiable by the INSA test accounts and scope table provided in the *Web Application Security Audit Documentation*. Requirement identifiers (`FR-XX-NNN`, `NFR-XX-NNN`) are stable across this document set for audit traceability.

4.2 Verification Methods

Requirement class	Verification method
Functional (FR-)	Demonstration via the storefront/admin UI and API calls using the provided test accounts; inspection of endpoint behaviour.
Security (NFR-SEC)	Penetration testing, code review, configuration inspection, and review of the security architecture diagram.
Performance (NFR-PERF)	Load testing and observation of /q/metrics.
Compliance (NFR-COMP)	Inspection of payment flow (no card data on servers), invoice sequences, and this document set.

4.3 Contact Information

Name	Role	Address (Email and Mobile)
[Primary technical contact name]	Technical Lead, Gadaa Istar e-commerce platform	Email: [tech-contact@gadaaistar.et] · Mobile: [+251-xxx-xxx-xxxx]
[Secondary technical contact name]	DevOps / Infrastructure	Email: [devops@gadaaistar.et] · Mobile: [+251-xxx-xxx-xxxx]
Gadaa Istar J&M Business Group plc	Company	Email: info@gadaaistar.et · Address: Addis Ababa, Ethiopia

> **Note:** Specific names and phone numbers for the primary and secondary technical contacts will be filled in before submission. These personnel can provide test accounts, allowlist INSA IPs on Cloudflare/WAF, disable rate limiting in staging, and answer technical questions during the audit.

5. Conclusion

This Software Requirements Specification defines the functional and non-functional behaviour of the Gadaa Istar Export E-Commerce Platform at a level suitable for INSA's security audit and for ongoing engineering traceability. It is submitted alongside the companion **System & Architecture Design Document (SDD)** and the **Web Application Security Audit Documentation** to provide INSA with a complete, verifiable picture of the system under test. The platform has been designed from inception with security, compliance (PCI DSS SAQ-A, ERCA VAT), and defense-in-depth as first-class requirements, and the Gadaa Istar engineering team is available to support the audit with test accounts, IP allowlisting, and staging configuration as needed.

End of Software Requirements Specification — Document version 1.0, July 2026.